

Halden Distribution Ltd. — vulnerability exception and risk-acceptance register

Document: P5-REG-001 · **Owner:** IT · **Approved by:** Finance Director (risk authority) **Purpose:** to record every decision *not* to fix a finding within its target window, who accepted the risk, the control that reduces it, and when the exception must be reviewed again.

Home-lab artefact. The table below is empty apart from one **worked example** that is clearly labelled as such. It is illustrative, not a real accepted risk, and it must be removed or replaced when this register is first used for real.

How to use this register

1. An exception is raised only when a finding cannot be remediated inside its tier target.
2. It requires: a named business owner, a compensating control, an expiry date **≤ 90 days**, and the reason it cannot be fixed.
1. IT records it here and adds a link to the ticket. An unchallenged exception is not an exception — the point is that the risk is visible and owned.
1. On expiry the exception is re-reviewed. If it is not re-reviewed, the finding returns to its original tier as an open item.

Register

ID	Date raised	Finding (host / CVE / tier)	Reason not remediated	Compensating control	Risk owner (name, role)	Accepted until	Review outcome
—	—	(no live entries — nothing has been remediated or accepted yet)	—	—	—	—	—
EX-000 (worked example only)	2026-10-02	LNx01 / legacy internal application requires an outdated runtime / P2	The vendor has no fixed release; upgrading the runtime breaks the application and there is no replacement budget this year	Application published only on the internal servers segment; the vulnerable service port is blocked at the firewall except from the application gateway	(example: Finance Director, not a real acceptance)	2026-12-31	Not reviewed — example only

Closed exceptions

ID	Finding	Closed on	How it was resolved
(none yet)	—	—	—

Reporting

The monthly vulnerability report summarises: the number of live exceptions, the number expiring in the next 30 days, and any exception that has expired without review. Those are reported as facts from this register, not as an estimate.

Note on scale: this register is part of a home-lab build for a fictional company. No entry here represents a real accepted risk on any real system.